Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

PRINCIPLES OF INFORMATION SECURITY

Attacks, people, risk and continuity



Day 9 - Morning

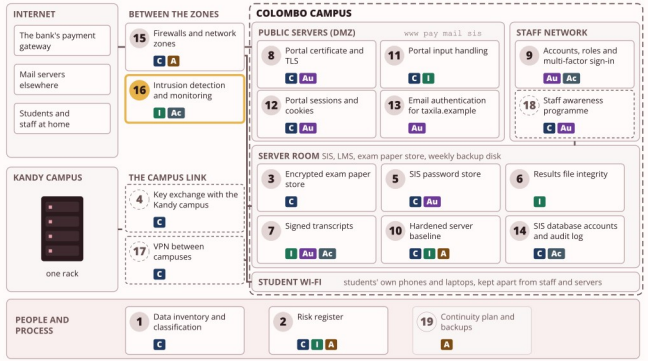
Running case: Taxila College, a fictional college

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

Today

How attacks differ, why people are targets, and how a college keeps running.

- Classifying an attack - 30 min
- Malware - 30 min
- Social engineering, the law and privacy - 30 min
- Managing risk - 30 min
- Keeping the college running - 30 min



TODAY

18 Staff awareness programme

Today serves two outcomes

LO1 Explain the fundamentals of information security.

LO2 Discuss the key characteristics of cryptography and cryptographic systems.

LO3 Analyze the principles of encryption, decryption, hashing, and data integrity.

LO4 Outline the process of ensuring digital security.

LO5 Describe the fundamentals of threats and countermeasures.

LO6 Explain the fundamentals and process of business continuity planning.

Where we start

RECALL

A threat exploits a vulnerability to put an asset at risk.

- **Availability** is the property that keeps a service answering
- Sniffing is **passive**; a flood is **active**
- **Phishing** tricks people into giving away a password
- **Least privilege**: the minimum access an account needs

Today the threats of eight days meet one plan.

Results week at Taxila

- The fee page **stopped** for three hours on deadline night
- The only backup is **one weekly disk**, never restored
- Two staff **followed** the fake Registrar link

T TAXILA

The fee payment page and the SIS back within a stated time after a failure, with little data lost.

R

REGISTRAR

If the Student Information System stopped tonight, how long could we wait? And how many grades would we lose?

The Registrar, on the ninth day of your placement.

CONCEPT 1

Classifying an attack

The changed grade was likely an insider; a mass phishing run is opportunistic.

TRY IT FIRST

Classify an attack on three axes.

30 min

Demonstration: three questions for any attack

1. Read the changed grade and set its three switches
2. Check, and read why each answer fits
3. Profile the false reply on the staff network
4. Compare the worm with the flood on deadline night

The profile points to the controls that fit.

Three axes describe any attack

Axis 1

Passive or active

Only watches, or sends, changes, blocks or deletes

*Passive leaves **no trace***

Axis 2

Insider or outsider

Already has access, or starts with none

*Insiders hold **passwords***

Axis 3

Targeted or opportunistic

Chose this victim, or took whoever was open

*Targeted attackers **keep trying***

Together the three answers give the attack's profile.

The profile picks the control

- Passive: **encrypt**, because watching for watchers does not work
- Insider: **least privilege** and a record of who did what
- Opportunistic: **patching** removes most of it
- Targeted: controls in **layers**
- An insider may act by **mistake**, not malice

Describing a burglary

YOU ALREADY KNOW THIS

Did the burglar only look, or break in? Staff or stranger? Your house chosen, or the first unlocked door?

MAPPING

watching against breaking in = passive against active · **a staff member against a stranger =** insider against outsider · **chosen against first-unlocked =** targeted against opportunistic

T TAXILA

The changed grade was likely an insider; a mass phishing run is opportunistic.

× COMMON MISTAKE

An attacker is always an outsider.

Insiders, by malice or mistake, are among the hardest to catch.

CONCEPT 2

Malware

Ransomware on the SIS would hold grades hostage, hurting availability and integrity.

TRY IT FIRST

A virus needs a host and a click; a worm moves itself; ransomware encrypts.

30 min

Demonstration: how malware spreads

1. Virus: open the file on the Registrar's computer
2. Worm: press Start and watch, with no click
3. Worm again, with every computer patched
4. Ransomware: watch the files lock

A virus needs a person; a worm needs a weakness.

A virus and a worm

Needs a person

Virus

- Hides in a **host file**
- Runs when someone **opens** it
- Spreads as the file is passed on

Needs a weakness

Worm

- Needs **no file** and no click
- Finds the next machine with the **same weakness**
- One unpatched server can infect a network in minutes

Awareness slows a virus; only patching stops a worm.

Six kinds of malware

6
kinds of malware

1
needs a person: the virus

0
products that stop them all

Kind	How it spreads or hides	What it does
Virus	a host file and a click	copies itself into files
Worm	by itself through a weakness	reaches every open machine
Trojan	inside something wanted	does harm behind it
Ransomware	**as any of the above**	**encrypts files for payment**
Spyware	quietly in the background	watches and reports
Rootkit	hides itself and others	keeps an attacker hidden

One layer for each kind

- **Patching** closes the weaknesses worms use
- **Least privilege** limits what one account can reach
- **Anti-malware** software recognises known malware
- **Awareness** stops the click and the trojan
- **Backups** malware cannot reach undo ransomware

Layered defences, not one product.

A flyer and a rumour

YOU ALREADY KNOW THIS

A flyer travels only when someone hands it on. A rumour spreads by itself.

MAPPING

a flyer someone must pass on by hand = a virus needing a host and a click · **a rumour that spreads by itself =** a worm moving across the network

T TAXILA

Ransomware on the SIS would hold grades hostage.

× COMMON MISTAKE

A virus and a worm are the same thing.

A virus needs a host and a click; a worm moves on its own.

CONCEPT 3

Social engineering, the law and privacy

Two staff followed the fake Registrar link; an awareness programme and the Data Protection Officer's duties are the answer.

TRY IT FIRST

The six triggers, and which one a message pulls.

30 min

Demonstration: which button does it press?

1. Read the email from the Registrar
2. Name the trigger it pulls hardest
3. Read the defence that stops it
4. Do the same for the memory stick and the door

Name the trigger, and the approach loses its power.

Attacking people, not systems

- **Phishing**: a message, as on Day 7
- **Pretexting**: an invented story that makes a request seem normal
- **Baiting**: something tempting left to be picked up
- **Tailgating**: following someone through a locked door
- Each pulls a **trigger** so people act before they think

Six triggers

6
common triggers

1
habit: check another way

18
awareness programme

Trigger	What it makes you feel
Authority	an important person is asking
Urgency	there is no time to check
Fear	something bad will happen
Reward	you will gain something
Curiosity	you want to see what it is
Helpfulness	a polite person needs help

The law and personal data

- Attacking any system without **written permission** is an offence
- Even a practice phishing exercise needs written **approval**
- The list of who clicked is **personal data**
- Taxila is the **data controller** for its people's data
- GDPR, the General Data Protection Regulation, for comparison

Computer Crime Act, No. 24 of 2007; Personal Data Protection Act, No. 9 of 2022, as amended.

A confidence trick at the door

YOU ALREADY KNOW THIS

A man in a smart uniform says your supply will be cut in ten minutes unless he checks the meter now.

MAPPING

the uniform that makes you comply = authority · **the act-now demand =** urgency

T TAXILA

Two staff followed the fake Registrar link.

× COMMON MISTAKE

Good technical controls stop social engineering.

It attacks people, not systems; awareness is the main control.

CONCEPT 4

Managing risk

The Head of IT cannot fix everything at once, so the register is prioritised.

TRY IT FIRST

Choose a treatment and see the residual risk.

30 min

Demonstration: four ways to treat a risk

1. Choose a treatment for the old test web server
2. Treat the card numbers on the fee page
3. Treat the exam paper folder
4. Accept the catalogue risk, and record its owner

Something usually remains: the residual risk.

Managing risk is a cycle

1. **Identify** assets, threats and vulnerabilities
2. **Rate** likelihood and impact, 1 to 5 each
3. **Treat** the highest scores first
4. **Record** the treatment and the owner
5. **Review** when threats or systems change

Four treatments

4
ways to treat a risk

1
owner for every risk

rest
the residual risk

Treatment	What you do	Taxila
Mitigate	add a control	encrypt the exam paper store
Avoid	stop the activity	switch off the old test server
Transfer	another party carries it	the bank's gateway holds card numbers
Accept	live with it as a recorded choice	a defaced catalogue page

STRIDE names six kinds of threat

5
attack a property

1
defeats a process

6
kinds of threat

Threat	Attacks	Taxila
Spoofing	authenticity	the fake Registrar email
Tampering	integrity	the changed grade
Repudiation	accountability	nobody could prove who
Information disclosure	confidentiality	the leaked paper
Denial of service	availability	the dead fee page
Elevation of privilege	**authorisation (a process)**	**a student with lecturer rights**

Policies and frameworks

- A **security policy** is a short rule everyone must follow
- The NIST Cybersecurity Framework sorts work into six functions
- Govern, identify, protect, detect, respond, recover
- ISO/IEC 27001: what a security management system must contain
- Organisations can be **certified** against it

A leaky roof

YOU ALREADY KNOW THIS

Your roof leaks over one room. Fix it, stop using the room, insure it, or put a bucket under it.

MAPPING

fix the roof = mitigate · **stop using the room =** avoid · **insure it =** transfer · **live with it =** accept

T TAXILA

The register is prioritised, because the Head of IT cannot fix everything at once.

× COMMON MISTAKE

Accepting a risk means ignoring it.

It is a recorded, owned choice to live with a measured risk.

CONCEPT 5

Keeping the college running

The dead fee-payment night needed a continuity plan with a stated recovery time.

TRY IT FIRST

The last-backup and recovery points set the data-loss window and the downtime.

30 min

Demonstration: two windows on one timeline

1. Choose the SIS in a marking week
2. Slide the last backup and the recovery point
3. Show Taxila today, with its weekly disk
4. Show a plan that meets both targets

Data lost and time down are two windows.

Planning for the failure that comes anyway

- **Business continuity planning** keeps critical work going
- A **business impact analysis** finds which services matter most
- Harm after one hour, one day, one week
- Then the **order** in which services come back

Two numbers for each service

Tolerable downtime

Recovery time objective, RTO

- How long the service may be **down**
- Met by standby servers and tested restores

Tolerable data loss

Recovery point objective, RPO

- How much data, in time, may be **lost**
- Sets how **often** you back up

An RPO of one hour needs a backup at least every hour.

Where to recover

Hot site
minutes

Always running

A second copy of the systems, ready now

*Costs the **most***

Warm site
hours

Equipment ready

The latest data must be loaded first

A middle path

Cold site
days

A room with power

Equipment and data must be brought in

*Costs the **least***

Faster recovery costs more; the recovery time decides how fast you need.

What keeps the plan working

- **Three-two-one**: three copies, two kinds of storage, one off-site
- **Failover**: a standby takes over automatically
- **Plan testing**: walk-through, tabletop, a real restore
- **Incident response**: detect, contain, recover, learn

Respond and recover are two of the framework's six functions.

A shop in a power cut

YOU ALREADY KNOW THIS

How long can a shop stay closed in a power cut? How many sales can it forget? So it notes sales every hour.

MAPPING

how long before you must reopen = the RTO · **the sales you can afford to lose =** the RPO · **the hourly note =** the backup

T TAXILA

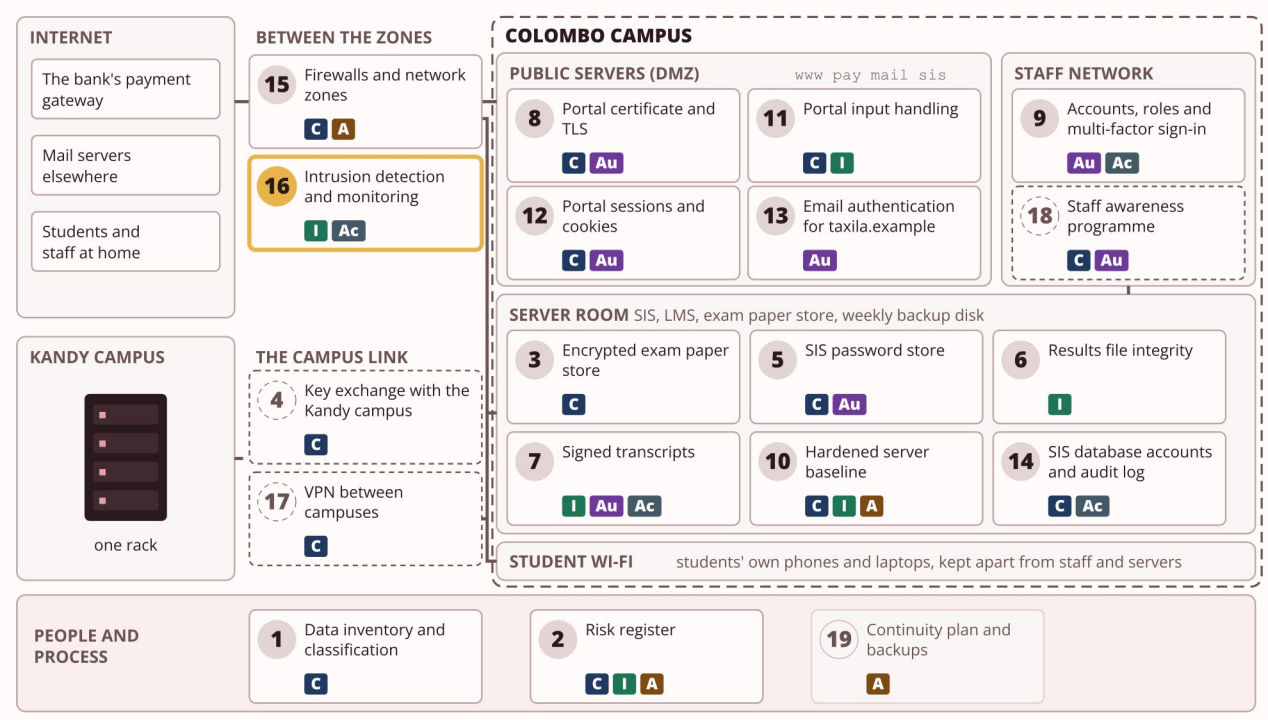
The dead fee-payment night needed a stated recovery time.

× COMMON MISTAKE

A backup you have never restored is a working backup.

Only a tested restore proves a backup.

The security register



TODAY

18 Staff awareness programme

KEY

- Added earlier
- Demonstrated
- Concept only
- Not yet added

Common mistakes

× COMMON MISTAKE

An attacker is always an outsider.

Insiders, by malice or mistake, are among the hardest to catch.

× COMMON MISTAKE

Accepting a risk means ignoring it.

It is a recorded, owned choice to live with a measured risk.

× COMMON MISTAKE

A backup you have never restored is a working backup.

Only a tested restore proves a backup.

Back to the weekly disk

Taxila's only backup is one weekly disk in the server room, never restored. Name what is wrong with it against the three-two-one rule, and against an RPO of one hour.

Before the next day

READ	**Security in Computing, chapters 3 and 10** Malware 3.2; continuity and risk 10.2 to 10.4
PRACTICE	**A ride-hailing app** Attack axes, risk treatments, a backup against a recovery point
TASK	**Your group's register** Prepare the risk register and controls map

Questions & Discussion

This afternoon: complete the risk register and write a continuity plan.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision c1d5b92